

ABHI SHARMA

Indore, India | +91 9424483008 | abhis9102@gmail.com | linkedin.com/in/a13h1
hackerone.com/root_a13h1 | medium.com/@a13h1 | abhis9102.github.io/a13h1

PROFESSIONAL SUMMARY

Security Operations Engineer with **4+** years of experience in vulnerability assessment, penetration testing, application security, and security operations across enterprise environments. Strong expertise in web/**API** security, vulnerability management, **threat modeling**, **SAST/DAST**, authentication, authorization, and incident investigation. Hands-on experience with **Burp Suite**, **OWASP ZAP**, Nmap, Metasploit, **Semgrep**, Nuclei, SQLMap, Python, and Bash. Experienced in identifying and remediating critical vulnerabilities, preparing **CVSS**-based security reports, collaborating with engineering teams, and performing remediation validation. Strong background in AWS security, attack-surface analysis, security automation, and offensive security research.

TECHNICAL SKILLS

- **Offensive Security:** Web App Pentesting, **API** Security Testing, Application Security, **Threat Modeling (STRIDE)**, Vulnerability Assessment, **Secure SDLC**, Security Reporting, **OWASP Top 10**, **CVSS**
- **Application Security Testing (SAST/DAST):** **Semgrep**, **CodeQL**, manual **secure code** review, **Burp Suite Professional**, **OWASP ZAP**, SQLMap, XSSStrike
- **Reconnaissance:** Katana, httpx, nuclei, ffuf, Amass, Subfinder, Assetfinder, LinkFinder, SecretFinder, gau, waybackurls
- **Network Security:** Nmap, Metasploit, Wireshark
- **Infrastructure:** Linux, Windows, Active Directory, SMB, Kerberos, DNS, TCP/IP, HTTP/HTTPS, SSH
- **Programming:** Java, Python, Bash, JavaScript
- **AI / Agentic Tooling:** Claude-based agent design (ReAct loop, tool orchestration, evidence/critic pipelines), LLM-assisted vulnerability research and triage
- **Cloud (AWS):** Core service fundamentals — EC2, S3, VPC, **IAM**, Lambda, RDS, CloudWatch, security-focused: **IAM** policy analysis, role assumption and privilege-escalation paths, S3/storage exposure, instance metadata (**SSRF-to-IMDS**)

EXPERIENCE

Security Operations Engineer

PRONEXUS CONSULTING PVT.LTD.

Oct 2022 – Present

- Perform **end-to-end** security assessments and penetration testing for **enterprise** web applications, REST APIs, and cloud-based environments, identifying security vulnerabilities across authentication, authorization, session management, and business logic.
- Investigate and validate security findings including **Broken Access Control**, **IDOR/BOLA**, **SQL Injection**, **XSS**, **SSRF**, **CSRF**, **privilege escalation**, authentication flaws, and business logic vulnerabilities.
- Perform security testing using **Burp Suite Professional**, **OWASP ZAP**, Nmap, Metasploit, SQLMap, Nuclei, **Semgrep**, ffuf, httpx, and related offensive security tools.
- Conduct **threat modeling** using **STRIDE** to identify potential attack vectors, trust-boundary violations, authentication/authorization weaknesses, and security risks during application and **API** assessments.
- Perform **secure code** review and **SAST** analysis using **Semgrep**, tracing security findings to source-code paths and validating whether identified issues are practically exploitable, correlate with dynamic application security testing (**DAST**) to reduce false positives and identify high-impact vulnerabilities.
- Investigate authentication and session-management issues, including improper access controls, session expiration weaknesses, **privilege escalation**, and unauthorized access scenarios.
- Assess **API** security by testing **REST** and **GraphQL** endpoints for authorization bypass, tenant isolation failures, excessive privilege, insecure direct object references, and improper input validation.
- Authored internal secure-coding and vulnerability-prevention documentation targeting common low-hanging findings (**XSS**, unsanitized input, **IDOR**, **Broken Access Control**, business-logic flaws, null-pointer/DoS-prone patterns), reducing recurrence of these classes in later-stage **DAST** and manual testing by **90%**.
- Built **Automated Reconnaissance Framework**, an automation pipeline integrating multiple open-source tools (subdomain enumeration, HTTP probing, JavaScript analysis, endpoint discovery, technology fingerprinting, and vulnerability scanning), to perform end-to-end reconnaissance and attack-surface mapping.
- Analyze AWS security configurations across services including EC2, S3, VPC, **IAM**, Lambda, RDS, and CloudWatch, with emphasis on **IAM privilege escalation**, storage exposure, role assumptions, and **SSRF-to-IMDS** attack paths.

- Prepare detailed security reports containing severity ratings, **CVSS** scores, business impact, reproduction steps, technical evidence, and remediation recommendations for engineering and client **stakeholders**, collaborate with engineering teams through remediation and re-validation cycles to confirm fixes are fully resolved.
- Leverage **AI** tooling to rapidly generate attack hypotheses and novel test scenarios against product features during manual testing, reducing average **time-to-detect** for vulnerabilities by **70%** versus manual-only testing.
- **Embed security review** into the development lifecycle for new features and product designs using a developer-first approach, ensuring secure coding protocols are addressed from the design phase onward rather than caught late in testing.

Cyber Security Consultant

CERTREE (UBERTAL INDIA PVT. LTD.)

Feb 2022 – Aug 2022

- Conducted application security assessments of Certree, a **zero-trust** document verification and storage platform handling sensitive personal and employment records.
- Separate real risk from scanner noise: run **Semgrep**-based **secure code** review, tracing scanner output back to exploitable paths and discarding findings that aren't reachable in practice.
- Corroborate design-level, source-level and runtime evidence before reporting a finding, by pairing **SAST** with dynamic testing (**DAST**) in **Burp Suite Professional** and **OWASP ZAP**.
- Identified and reported **38** confirmed vulnerabilities, spanning 13 **XSS**, 10 **Broken Access Control**, 7 **IDOR**, 3 **SSRF** via PDF rendering, 2 HTML Injection, and 3 **Privilege Escalation** issues that could expose sensitive document data, plus multiple additional low-severity findings (session management, session expiration).
- Collaborate with developers to validate findings and document them in structured reports (severity ratings, reproduction steps, remediation guidance) for the engineering team.
- Retest and verify fixes across remediation cycles, confirming vulnerabilities were fully resolved before sign-off.
- Produce security best-practice guidance to educate staff on common threats and attack vectors, sustaining product security beyond point-in-time testing.

PROJECTS

Hackbot (Custom Agentic Vulnerability Research Framework): produced a confirmed, **CVSS**-scored, independently-reproduced cross-tenant **BOLA** finding on a production SaaS **GraphQL/REST API** using a Claude-powered autonomous pentesting agent (ReAct loop, critic module blocking unconfirmed findings, 25 methodology documents across major vulnerability classes).

Automated Reconnaissance Framework: Integrated open-source offensive security tooling for attack surface mapping, subdomain enumeration, HTTP probing, JavaScript analysis, endpoint discovery, and technology fingerprinting.

CERTIFICATIONS

Currently preparing: Offensive Security Certified Professional (OSCP)

EDUCATION

Sri Aurobindo Institute of Technology, Indore, Madhya Pradesh

Bachelor of Technology in Computer Science and Engineering, CGPA 6.55, Class of 2022

ACHIEVEMENTS

- **HackerOne**: **4,000+** reputation, **100+** valid vulnerability reports submitted and resolved.
- **Client Recommendations**: Formally recommended by the **Founder** of **Writing.com** and the **CTO** of Certree for penetration testing and security consulting work.
- **Technical Writing**: Published near-weekly on Medium and InfoSec Write-ups, translating real bounty findings (race conditions, business logic flaws, **API privilege escalation**) into methodology writeups shared with the security community.
- **Community**: Volunteer, BSides Goa.